# Risk analysis and management for ICT systems

**Introduction to risk management methodology, juridical aspects and case studies**

*Stefano Zatti and Raffaele Gargiulo*

DIPARTIMENTO
DI INFORMATICA




SAPIENZA
UNIVERSITÀ DI ROMA

# Risk management 2025

Mondays 8-11 Aula De Lollis 4, via Tiburtina 205

Thursdays 12-14 aula L2 via Castro Laurenziano

## Prof. Gargiulo (10 lezioni)

**Settembre**

- MON 28 RG

**Ottobre**

- THU 1 RG
- MON 5 RG
- THU 8
- MON 12 - RG

**Novembre**

- MON 2 RG
- THU 5 RG
- MON 9 RG
- THU 12 RG
- MON 16 RG
- THU 19 RG

## Prof. Zatti (10 lezioni)

**Ottobre**

- THU 15 SZ
- MON 19 SZ
- THU 22 SZ
- MON 26 SZ
- THU 29 SZ

**Novembre**

- MON 23 SZ
- THU 26 SZ
- MON 30 SZ

**Dicembre**

- THU 3 SZ
- MON 7 SZ

# Cyber-Risk analysis and management (ZATTI)

1. Introduction. The ISO 27000 family of standards
2. The ISO 27005 standard for management of cyber risks
3. Similar standards:  NIST 800-30
4. Methodologies: Octave, EBIOS, ...
5. The threat profile from ENISA
6. The implementation of the ISMS  - how to start a project – the phases of risk assessment
7. Risk evaluation: threats and vulnerabilities
8. Risk treatment: countermeasures and decision
9. Practical Cases: ICT systems
10. Practical Cases: Space Missions

# Personal Introduction: Stefano Zatti

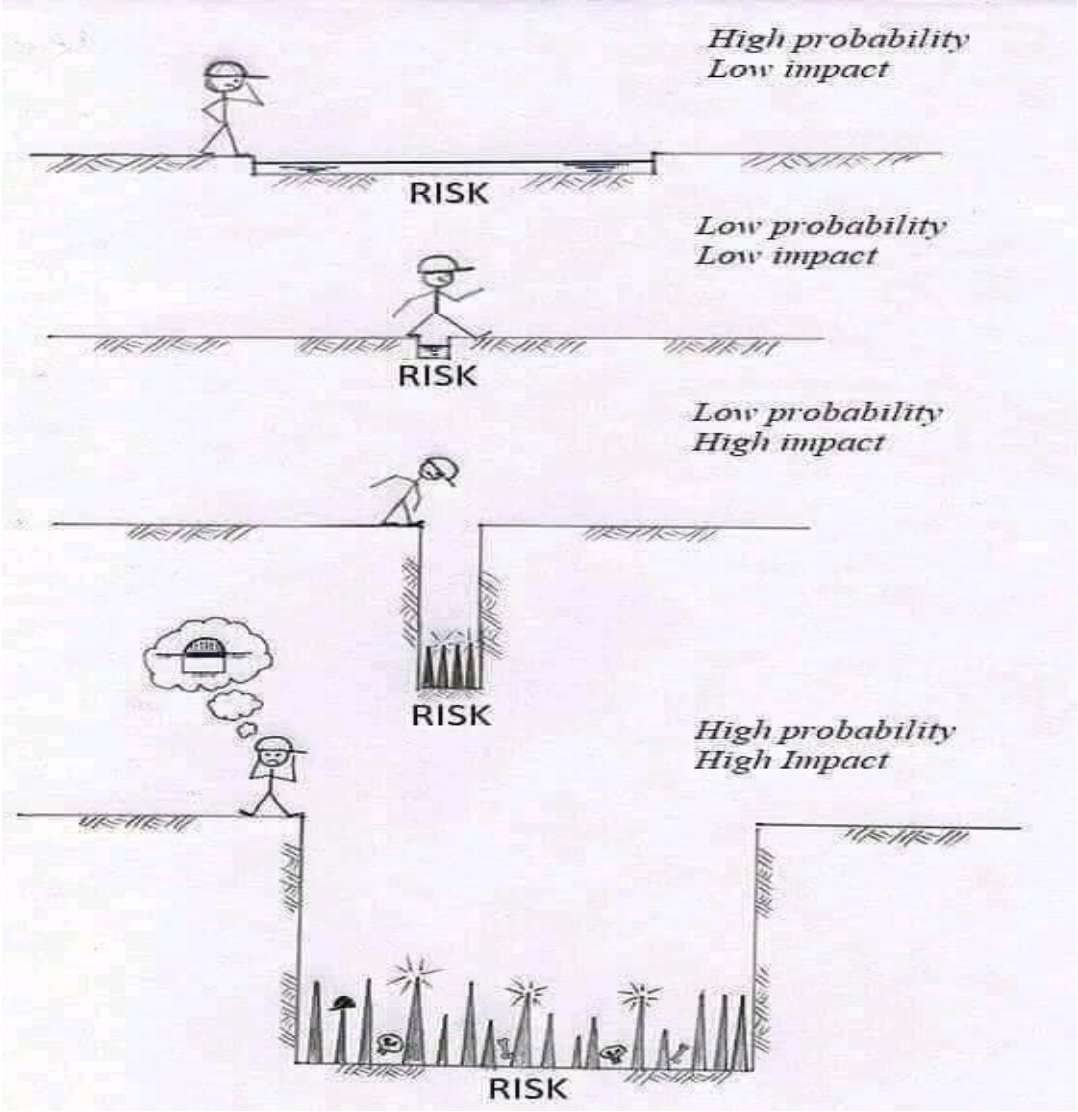


- Head of the European Space Agency's Security Office: 2006-2019
- Prior assignments:
  - ESA: Head of ITC engineering section
  - IBM Research CH - Crypto tools development: KryptoKnight project
  - UC Berkeley - Research assistant: Tempo, BSD Unix clock synchronization
- Academic assignments:
  - Università di Roma La Sapienza:
  - Master II livello: corso ASIA (2004-2017)
  - Corso di Laurea Magistrale in Cybersecurity: ***Risk Assessment*** (2019, 2020, 2021, 2022, 2023, 2024, 2025, 2026)
- Author of the book: "Il Nodo di Salomone", a cyber-medical thriller co-written with Dr Paolo Gaetani, neurosurgeon. Available on Amazon

# What is a risk?

- **Risk**: effect of uncertainty on objectives (ISO 31000)
- **Enterprise Risk Management** (ERM) has a broader scope (beyond cyber risks)
- In business, risk management is defined as the process of identifying, monitoring and **managing potential risks** in order to minimize the negative impact they may have on an organization. Examples of potential risks include security breaches, data loss, cyber attacks, system failures and natural disasters. An effective **risk management process** will help identify which risks pose the biggest threat to an organization and provide guidelines for handling them at the best level of resources.
- **The risk management process** consists of three parts: *risk identification and analysis*, *risk evaluation* and *risk treatment*.

# Assessing risk: probability vs. impact



# How do we manage risk?

**The 3 Steps of Risk Management:**

**Risk Identification & Analysis**

A risk assessment evaluates an organization's exposure to uncertain events that could impact its day-to-day operations and estimates the damage those events could have on an organization's revenue and reputation.

**Risk Evaluation**

A risk evaluation compares estimated risks against risk criteria that the organization has already established. Risk criteria can include associated costs and benefits, socio-economic factors, legal requirements and system malfunctions.

**Risk Treatment & Response**

is the implementation of policies and procedures that will help avoid or minimize risks. Risk treatment also extends to risk transfer and risk avoidance.

# How do we manage risk?

**The 3 Steps of Risk Management:**

**Risk Identification & Analysis**

A risk assessment evaluates an organization's exposure to uncertain events that could impact its day-to-day operations and estimates the damage those events could have on an organization's revenue and reputation.

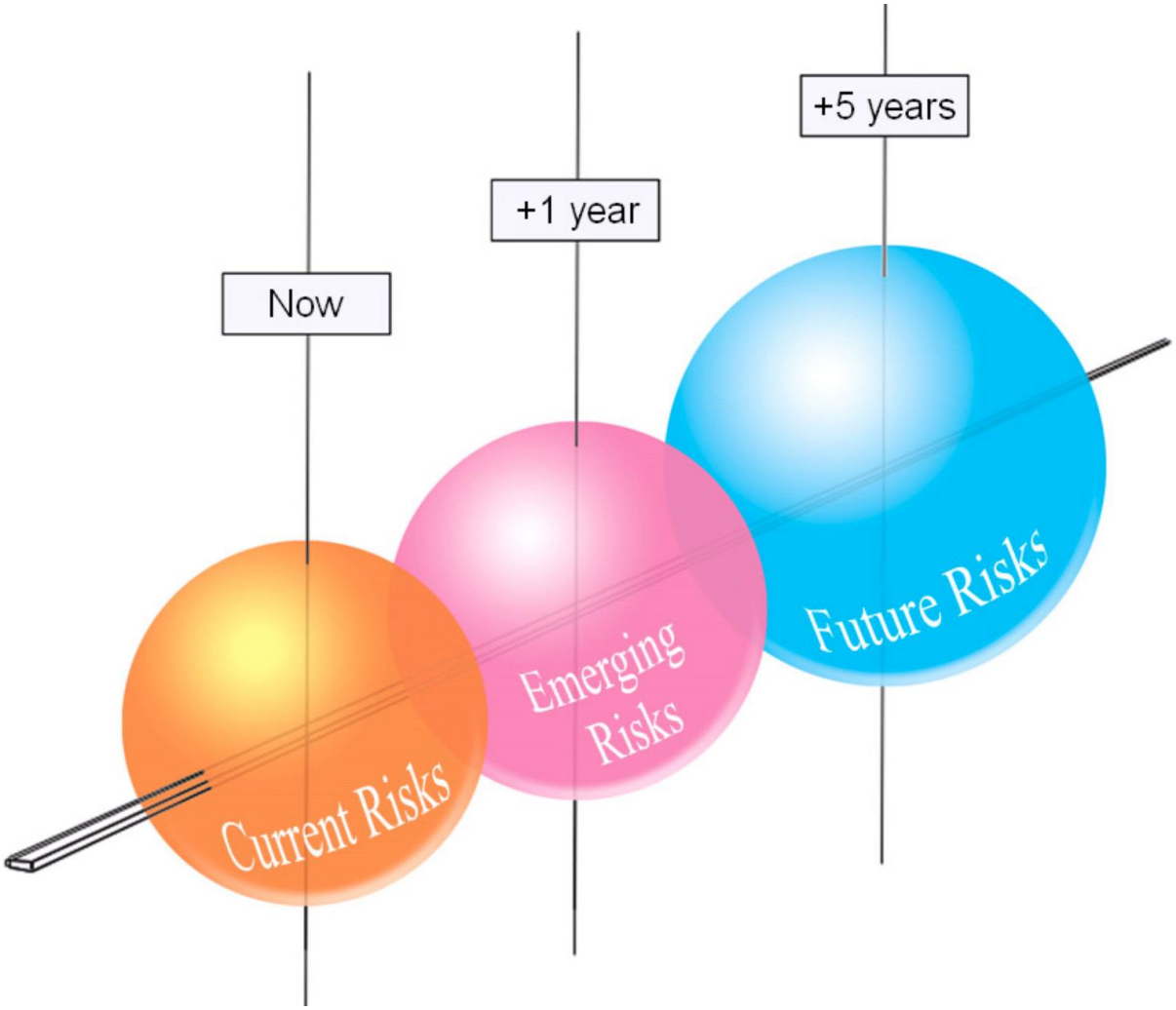
**Risk Evaluation**

A risk evaluation compares estimated risks against risk criteria that the organization has already established. Risk criteria can include associated costs and benefits, socio-economic factors, legal requirements and system malfunctions.

**Risk Treatment & Response**

is the implementation of policies and procedures that will help avoid or minimize risks. Risk treatment also extends to risk transfer and risk avoidance. In the end, residual risks can be accepted.

# Risks evolution in a trend



# The ISO 27X Standards Family

- **ISO/IEC 27000:2018** – Information technology Security techniques Information security management systems- Overview and vocabulary
- **ISO/IEC 27001:2022** Information security, cybersecurity and privacy protection - Information security management systems - Requirements
- **ISO/IEC 27002:2022** – Information security, cybersecurity and privacy protection - Information security controls
- **ISO/IEC 27003**, Information security management system implementation guidance - (in essence, a guide to implement ISO/IEC 27001)
- **ISO/IEC 27004**, Information security management — Measurement
- **ISO/IEC 27005:2022** Information security, cybersecurity and privacy protection – Guidance on managing information security risks
- **ISO/IEC 27014:2018** Information technology -- Security techniques – Governance of Information security
- **ISO/IEC 27017**, with controls for cloud services,
- **ISO/IEC 27032:2023** Cybersecurity -- Guidelines for Internet Security

# The ISO 27X Standards Family

- **ISO/IEC 27000:2018** – Information technology Security techniques Information security management systems- Overview and vocabulary
- **ISO/IEC 27001:2022** Information security, cybersecurity and privacy protection - Information security management systems - Requirements
- **ISO/IEC 27002:2022** – Information security, cybersecurity and privacy protection - Information security controls
- **ISO/IEC 27003**, Information security management system implementation guidance
- **ISO/IEC 27004**, Information security management — Measurement
- **ISO/IEC 27005:2022** Information security, cybersecurity and privacy protection – Guidance on managing information security risks
- **ISO/IEC 27014:2018** Information technology -- Security techniques – Governance of Information security
- **ISO/IEC 27032:2023** Cybersecurity -- Guidelines for Internet Security

# The ISO 27X Standards Family

- **ISO/IEC 27000:2018** – Information technology Security techniques Information security management systems- Overview and vocabulary
- **ISO/IEC 27001:2022** Information security, cybersecurity and privacy protection - Information security management systems - Requirements
- **ISO/IEC 27002:2022** – Information security, cybersecurity and privacy protection - Information security controls
- **ISO/IEC 27003**, Information security management system implementation guidance
- **ISO/IEC 27004**, Information security management — Measurement
- **ISO/IEC 27005:2022** Information security, cybersecurity and privacy protection – Guidance on managing information security risks
- **ISO/IEC 27014:2018** Information technology -- Security techniques – Governance of Information security
- **ISO/IEC 27032:2023** Cybersecurity -- Guidelines for Internet Security

# Relevant textbooks on Cybersecurity

**EFFECTIVE CYBERSECURITY:** A guide to using best practices and standards, William Stallings, Addison-Wesley, 2019



**IT GOVERNANCE:** An international guide to data security and ISO27001/ISO27002, 6th Edition, Alan Calder & Steve Watkins



**FUNDAMENTALS OF INFORMATION SECURITY, 2nd Edition:** David Kim and Michael G. Solomon

# Recommended reading



INTERNATIONAL STANDARD

**ISO/IEC 27001**

Third edition
2022-10

# Information security, cybersecurity and privacy protection — Information security management systems — Requirements

*Sécurité de l'information, cybersécurité et protection de la vie privée — Systèmes de management de la sécurité de l'information — Exigences*

Dit document mag slechts op een stand-alone PC worden geïnstalleerd. Gebruik op een netwerk is alleen toegestaan als een aanvullende licentieovereenkomst voor netwerkgebruik met NEN is afgesloten.
This document may only be used on a stand-alone PC. Use in a network is only permitted when a supplementary license agreement for use in a network with NEN has been concluded.

Reference number
ISO/IEC 27001:2022(E)

© ISO/IEC 2022

Dit document is door NEN onder licentie verstrekt aan: / This document has been supplied under license by NEN to:
ESA Library gb_esalibrary 2023-03-06 14:49:09

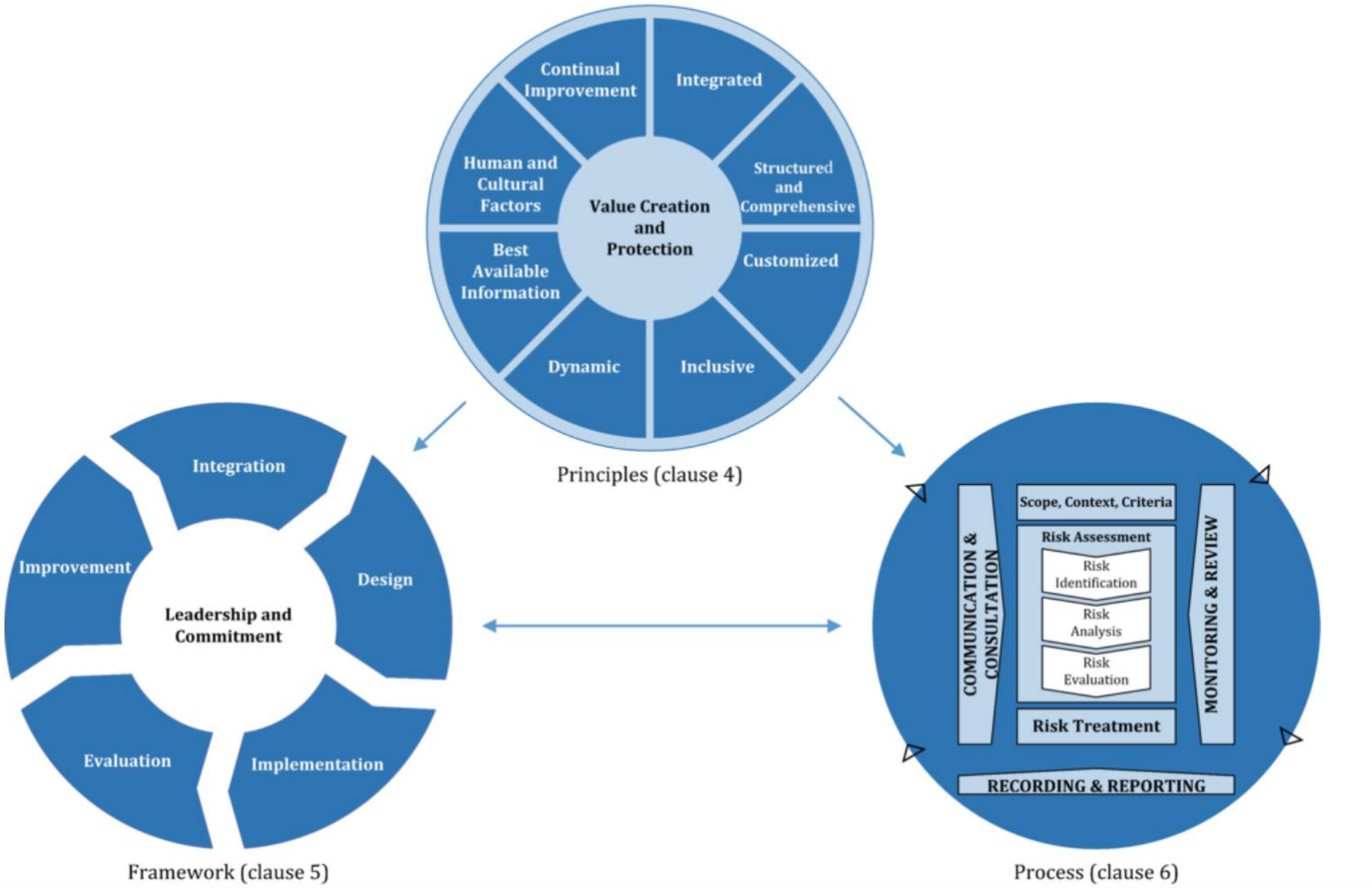
# ISO 27000

- A family of standards for IT and Communications Systems Security, published by ISO
- Builds an Information Security Management System (ISMS)
- Based on the **P**lan-**D**o-**C**heck-**A**ct cycle
- Provide trust to / from third parties
- Aimed at effectiveness: *spend as much as you need to counter your risks*
- Protect the **C**onfidentiality-**I**ntegrity-**A**vailability information triad
- ISO 27001 uses a top down, risk-based approach and is technology-neutral:
  - Defining ISMS scope
  - Developing the risk assessment (which risks are under direct control and which not)
  - Selection of controls
  - Statement of Applicability
  - Reviewing risks
  - Management commitment
  - ISMS internal audits
  - Results of effectiveness and measurements
    (summarised statement on 'measures of effectiveness')
  - Specify the details for documentation, management responsibility, internal audits, continuous improvement, and corrective and preventive action.

# Also relevant

- ISO/IEC 31000:2018, Risk management – Principles and guidelines

**Figure 1 — Principles, framework and process**



# Security management standards

## ISO/IEC 27001:2022

Requirements for information security management system

1. Scope of the standard
2. Normative references. How the document is referenced
3. Reuse of the terms and definitions in ISO/IEC 27000
4. Context of the Organization
5. Leadership and high-level support for policy
6. Planning the information security management system; risk assessment; risk treatment
7. Support for the information security management system
8. Operation: Making an information security management system operational
9. Performance evaluation: Reviewing the system's performance
10. Improvement. Corrective actions

Annex A: List of controls and their objectives.

# Security management standards

**ISO/IEC 27001:2022**

Requirements for the information security management system

**ISMS** = Information Security Management System

An Information Security Management System (**ISMS**) is a systematic approach to managing sensitive information so that it remains secure.
It includes policies, procedures, plans, roles, responsibilities, structures used to protect and preserve information.

It is based on a risk management process.

The ISO 27000 family of standards has been developed to help for ISMS implementation and maintenance, on the basis of a cycle of continuous improvement.

# The provision mandated by ISO 27001 on RISK management

- 6.1.2. Information Security Risk assessment
  - The organization shall define and apply an Information security risk assessment process.
- 6.1.3. Information Security Risk treatment
  - The organization shall define and apply an information security risk treatment process.
- 9.2 Internal audit
  - The organization shall conduct internal audits at planned intervals, to provide information on whether the ISMS conforms to the requirements and is effectively implemented.
- 9.3 Management review
  - Top management shall review the organization's ISMS at planned intervals, to ensure its continuing suitability, adequacy and effectiveness.
- Annex A (normative) contains the (93) information security controls, aligned with ISO 27002

# Documented Information: it is a MUST

- Scope 4.3
- Policy 5.2
- Risk assessment process 6.1.2
- Risk treatment process 6.1.3
- Information  Security Objectives 6.2
- Evidence of Competence of staff 7.2
- Documented information as determined being necessary 7.5.1
- Risk assessment results 8.2
- Risk treatment results 8.3
- Evidence of monitoring of and measurement results 9.1
- Evidence of internal audit and audit results 9.2
- Evidence of management review results 9.3
- Evidence of treatment of non-conformities 9.4

# Documented Information: it is a MUST

- Scope 4.3
- Policy 5.2
- Risk assessment process 6.1.2
- Risk Treatment Process 6.1.3
- Information  Security Objectives 6.2
- Evidence of Competence of staff 7.2
- Documented information as determined being necessary 7.5.1
- Risk assessment results 8.2
- Risk treatment results 8.3
- Evidence of monitoring of and measurement results 9.1
- Evidence of internal audit and audit results 9.2
- Evidence of management review results 9.3
- Evidence of treatment of non-conformities 9.4

# Security management standards

## ISO/IEC 27001:2022

Requirements for information security management system

- Information security controls reference (93) – Annex A
  - A.5: Organizational controls (37 controls)
  - A.6: People controls (8 controls)
  - A.7: Physical controls (14 controls)
  - A.8: Technological controls (34 controls)
- We will see them in detail in lesson 7 (as part of risk treatment)

# The new version of ISO 27001 was issued in November 2022

- What's changing in ISO 27001?
  - ISO 27001:2022 is not significantly different from ISO 27001:2013, but there are some notable changes:
- Context and scope
  - You must now identify the "relevant" requirements of interested parties and determine which will be addressed through the ISMS (information security management system).
  - The ISMS now explicitly includes the "processes needed and their interactions".
- Planning
  - Information security objectives must now be monitored and made "available as documented information".
  - There is a new section on planning changes to the ISMS. This does not specify any processes that must be included, so you should determine how you can demonstrate that changes to the ISMS have indeed been planned.

# The new version of ISO 27001 was issued in November 2022

- Support
  - The requirements to define who will communicate and the processes for effecting communication have been replaced by a requirement to define "how to communicate".
- Operation
  - The requirement to plan how to achieve information security objectives has been replaced by a requirement to ***establish criteria*** for processes to implement actions identified in Clause 6, and to ***control*** those processes in line with the criteria.
  - Organisations are now required to control "externally provided processes, products or services" relevant to the ISMS.
- Performance and evaluation
  - Methods of monitoring, measuring, analysing and evaluating the effectiveness of the ISMS now need to be comparable and reproducible.
  - The management review must now also consider changes in the needs and expectations of interested parties.
- Annex A
  - Annex A has been revised to align it with ISO 27002:2022. 93 controls

And what about cybersecurity?

# Definition of “Cybersecurity”

*von Solms R, van Niekerk J, From information security to cyber security, Computers & Security (2013), http://dx.doi.org/10.1016/j.cose.2013.04.004*

*Cyber security:.....many current publications dealing with cyber security use the term cyber security interchangeably with the term information security. If cyber security is synonymous with information security it would be reasonable to assume that cyber security incidents could also be described in terms of the characteristics used to define information security.*

*Thus, a cyber security incident would, for example, also lead to a breach in the confidentiality, integrity or availability of information. This is true for the majority of cyber security related threats a user and/or organisation might be exposed to. However, it is the contention of this paper that there are cyber security threats that do not form part of the formally defined scope of information security. This section will briefly present a few scenarios as examples:*

Scenario 1 - Cyber bullying: *The need to address cyber bullying has become widely acknowledged as a cyber security problem and is even mentioned specifically in the UK Cyber Security Strategy (Minister for the Cabinet Office and Paymaster General, 2011, p. 26). However, being bullied in cyberspace does not constitute a loss of confidentiality, integrity or availability of information. Instead, the target of such activities is the user him/ herself. Accordingly, cyber bullying results in direct harm to the person being bullied*

Scenario 2 - Home automation: *the increased convenience of managing one’s home via the web is accompanied by the increased risk that someone might gain unauthorised access to such systems and cause harm. This harm could range from “pranks” like turning off the hot water, to serious crimes like turning off the security system in order to burgle the home. Once again, in this case one can argue that the victim’s information is not necessarily negatively affected. Instead, other assets of the victim are the target of the cybercrime*

Scenario 3 - Digital media *One of the industries that have been directly affected by the improved sharing of information is the entertainment industry. Every year enormous amounts of potential revenue are lost to the sharing of illegal movies, music and other forms of digital media. This illegal sharing does not necessarily affect the confidentiality, integrity or availability of the shared media; however, it does directly affect the financial wellbeing of the legal owner of the rights to the specific media*

Scenario 4 - Cyber terrorism *In the USA critical infrastructure is defined as “the assets, systems, and networks, whether physical or virtual, so vital to the United States that their incapacitation or destruction would have a debilitating effect on security, national economic security, public health or safety, or any combination thereof” (Department of Homeland Security, 2011).....attacks against such critical infrastructure, the loss entails not only of that of the integrity or availability of information resources, but also that of access to such critical services*

# Effective Cybersecurity

*Cybersecurity*

**Effective Cybersecurity, William Stallings**

*The collection of tools, policies, security concepts, security safeguards, guidelines, risk management approaches, actions, training, best practices, assurance, and technologies that can be used to protect the cyberspace environment and organization and users' assets.*

*Organization and user assets include connected computing devices, personnel, infrastructure, applications, services, telecommunications systems, and the totality of transmitted and/or stored information in the cyberspace environment.*

*Cybersecurity strives to ensure the attainment and maintenance of the security properties of the organization and users' assets against relevant security risks in the cyberspace environment. The general security objectives are availability; integrity, which may include authenticity and non-repudiation; and confidentiality.*

**ISO/IEC 27032: IT – Security Techniques - Guidelines for Cybersecurity**

*Cybersecurity – Cyberspace security*

*Preservation of confidentiality, integrity and availability in the Cyberspace.*

*Note 1. In addition, other properties, such as authenticity, accountability, non-repudiation, and reliability can also be involved.*

*Cyberspace*

*Complex environment resulting from the interaction of people, software and services on the Internet by means of technology devices and networks connected to it., which does not exist in any physical form.*

INTERNATIONAL STANDARD

**ISO/IEC 27032**

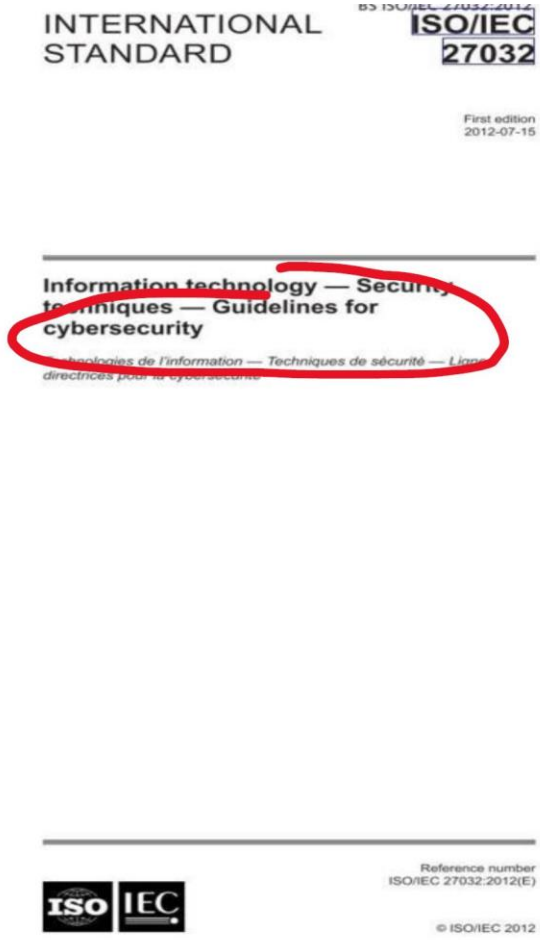
Second edition
2023-06

# Cybersecurity — Guidelines for Internet security

*Cybersécurité — Lignes directrices relatives à la sécurité sur l'internet*

ebruik op een netwerk is alleen
ik met NEN is afgesloten.
s only permitted when a
n concluded.

# Why?



INTERNATIONAL STANDARD

ISO/IEC 27032

First edition
2012-07-15

**Information technology — Security techniques — Guidelines for cybersecurity**

*Technologies de l'information — Techniques de sécurité — Lignes directrices pour la cybersécurité*

Reference number
ISO/IEC 27032:2012(E)

© ISO/IEC 2012

ISO 27032
IT SECURITY TECHNIQUES

GUIDELINES FOR CYBERSECURITY

| **ISO 27032**<br>*From http://www.iso.org/iso/home/news_index/news_archive/news.htm?refid=Ref1667* |
|---|
| Aims at addressing security gaps arising from the lack of communication between the different users and providers of cyberspace |
| The standard was designed because,<br>*"Devices and connected networks that support cyberspace have multiple owners – each with their own business, operational and regulatory concerns. Not only do the different users and providers share little or no input, but each has a different focus when dealing with security. Such a fragmented state opens up vulnerabilities in cyberspace. ISO/IEC 27032 will provide an overarching, collaborative, multi-stakeholder solution to reduce these risks."* |
| ISO/IEC 27032 provides a framework for:<br>● Information sharing<br>● Coordination<br>● Incident handling |

# 27001 versus 27032

| ISO 27001/2 | ISO 27032 |
|---|---|
| Requirements for certification/Code of Practice | Guidelines/Not Auditable/Not Certifiable |
| Focus on:<br>- Establishment and improvement of a comprehensive information security management program | Focus on:<br>- Information security<br>- Application security<br>- Network security<br>- Internet security |
| Includes control requirements & recommendations on 18 clauses:<br>- Mandatory clauses<br>- Information security policies<br>- Organization of information security<br>- HR security<br>- Asset management<br>- Access control<br>- Cryptography<br>- Physical and environmental security<br>- Operations security<br>- Communication security<br>- System acquisition, development and maintenance<br>- Supplier relationship<br>- Information security incident management<br>- Information security of business continuity management<br>- Compliance | Includes control recommendations on:<br>- Governance<br>- Technical measures for:<br>  - Social engineering<br>  - Hacking<br>  - Malware<br>  - Secure coding<br>- Incident information sharing: IPOs and IROs<br>- Readiness |
| | Extended scope than ISO27001, including:<br>- Transfer and Sharing of Information |
| RISK ASSESSMENT: Critical Assets -> Threats -> Vulnerabilities | |

# ISO 27032:2023
# Cybersecurity — Guidelines for Internet security

The focus of this document is to address Internet security issues and provide guidance for addressing common Internet security threats, such as:

— social engineering attacks;

— zero-day attacks;

— privacy attacks;

— hacking; and

— the proliferation of malicious software (malware), spyware and other potentially unwanted software.

# ISO 27032:2023
# Cybersecurity — Guidelines for Internet security

The guidance within this document provides technical and non-technical controls for addressing the Internet security risks, including controls for:

— preparing for attacks;

— preventing attacks;

— detecting and monitoring attacks; and

— responding to attacks.

The guidance focuses on providing industry best practices, broad consumer and employee education to assist interested parties in playing an active role to address the Internet security challenges.

The document also focuses on preservation of **confidentiality, integrity and availability** of information over the Internet and other properties, such as **authenticity, accountability, non-repudiation and reliability** that can also be involved.

# Collaboration among stakeholders

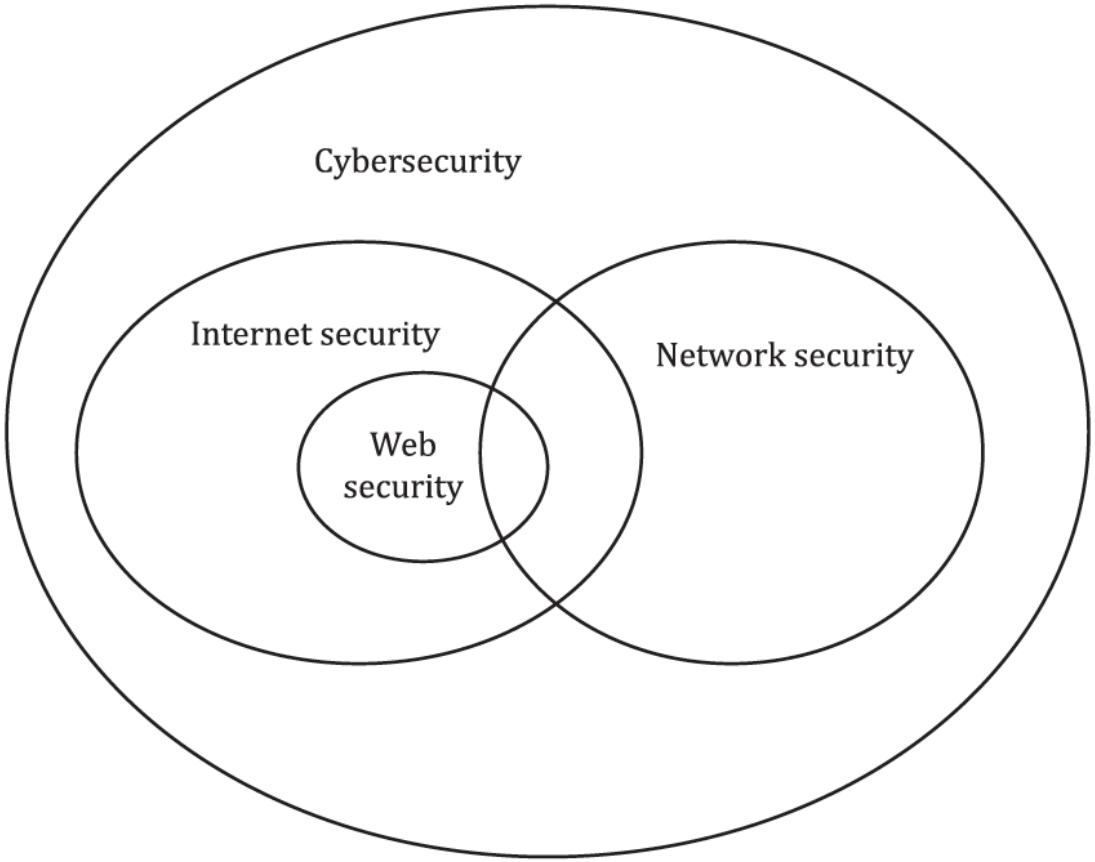
Stakeholders - Interested parties of Internet security include those who:

- use services over the Internet;
- use the Internet to provide services;
- provide the infrastructure and communicating capabilities of the Internet;
- globally coordinate the operation of the Internet;
- provide and enforce laws and regulations.

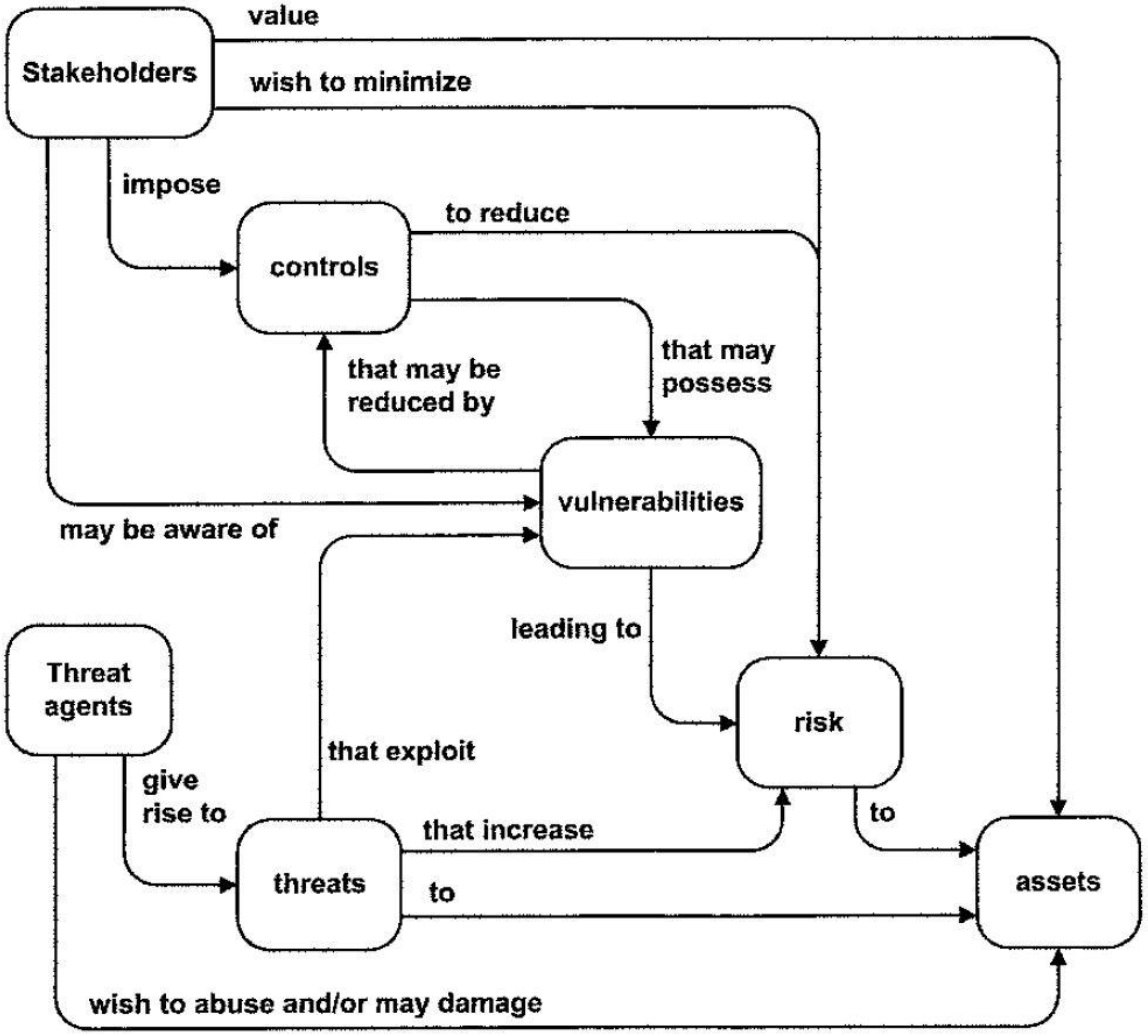
Provides a framework for establishing trust and processes for

- Information sharing
- Coordination
- Incident handling

# Cybersecurity and the security domains



# Security concepts and relationships



# Guidelines for stakeholders

- **Risk management -> ISO27005**

  Important aspects to remember when considering the goals and objectives of Cybersecurity are:

  a) protect the overall security of the Cyberspace;

  b) plan for emergencies and crises through participation in exercise, and update response plans and plans for continuity of operations;

  c) educate stakeholders on Cybersecurity and risk management practices;

  d) ensure timely, relevant and accurate threat information sharing between law enforcement and intelligence communities and key decision makers relevant to the Cyberspace; and

  e) establish effective cross-sector and cross-stakeholder coordination mechanisms to address critical interdependencies, including incident situational awareness and cross-sector and cross-stakeholder incident management.

# 9.2.1 Controls for Internet security: general

Organizations should develop **policies, procedures and response capability** to:

a) define the rules for acceptable use of the Internet by personnel;

b) define what services may be exposed over the Internet;

c) identify the threats, vulnerabilities, attack vectors and their associated risks;

d) define the roles and responsibilities of various users of the Internet;

e) conduct user awareness on the safe practices for Internet usage;

f) specify the responsible departments for handling Internet security issues;

g) establish a response mechanism for cybersecurity incidents;

h) conduct security drills to test the response mechanism towards attacks originating from the Internet.

Based on risk assessment, one can uncover the various relevant Internet security risks that can be addressed through the following controls.

# 9.2.2 Controls for Internet security: Policies for Internet security

- An organization should prepare and publish a **policy** concerning Internet usage by personnel and other relevant parties in alignment with security objectives.
- This policy determines which Internet services are used, who is authorized to use them, and what the security objectives are. This policy directs all other guidelines for the secure connection to, and use of, the Internet.
- Policies for Internet security should be defined, approved by management, published and communicated to, and acknowledged by, the relevant personnel, contractors and external parties.

# 9.2.3 Controls for Internet security: Access control

- Rules to control physical and logical access to information and assets, other assets associated with the Internet and information processing facilities should be established and implemented based on business and information value.
- Rights should be regularly reviewed and needs confirmed on the basis of the least-privilege principle.
- Rules regarding access to essential information and assets associated with information and information processing facilities should be in line with an established corporate access control policy and information classification policy.

# 9.2.4 Controls for Internet security: Education, awareness and training

- The organization's personnel (including top management, system admin, IT staff and privileged users, etc.) should be regularly updated on the main threats and the actions to be taken to prevent them and respond in case of improper action, addressing the numerous new threats that are launched on the Internet daily and are continuously evolving.

# 9.2.5 Controls for Internet security: Security incident management

- An incident management team (IMT, *typically called the CERT*) with a supporting incident response team (IRT) should be established to provide the organization with capability for assessing, responding to and learning from such incidents.
- Incident response procedures should consider detecting and reporting the occurrence of security events like potential and actual incidents by human or automatic means.
- Monitoring tools implemented by the organization can detect and send security events for incident response.

# 9.2.6 Controls for Internet security: Asset management

- ICT components containing critical information and applications should be identified, tracing where the assets are physically located in order to protect them adequately.
- Organizations should not only keep an inventory of up-to-date ICT assets within their control but should also maintain an information asset register (CMDB) of where their information is processed, stored, transferred, whether it is on their internal network or uses cloud/Internet-based hosting solutions.

# 9.2.7 Controls for Internet security: Supplier management

- Processes and procedures should be identified and implemented to manage the Internet security risks associated with the use of suppliers.
- All relevant information security requirements should be established and agreed with each supplier based on the type of supplier and associated risks.
- Risk management in relation with the ICT suppliers and the information they store, exploit or can have access to, is key for preparing contracts that ensure that the organization’s information security objectives are continuously achieved.

# 9.2.8 Controls for Internet security: Business continuity over the Internet

- Some business activities like Internet based trading and other e-commerce activities depend on the organization's Internet infrastructure within the organization.
- Disruptions to Internet services can be caused by DoS and DDoS attacks from bad actors, perimeter device malfunction or any disruption from the ISP end. DoS and DDoS attacks can also be conducted by bad actors on the ISP end that can result in complete outage of the Internet backbone.
- Information processing facilities should be implemented with redundancy sufficient to meet availability requirements.

# 9.2.9 Controls for Internet security: Privacy protection over the Internet

- Most service providers control or process PII (personally identifiable information) as part of their business services
- When this information is used for purposes different to the interests of the data principal, privacy concerns are raised.
- In addition to the data protection and personal privacy provisions on the Internet-facing site or application, service providers should require such sites or applications hosted on their networks to implement a set of best practice security controls at the application level before they go live.
- Prior to signing up to a service on the Internet, organizations should undertake a privacy impact assessment (PIA) to identify the personal information that can be used, collected, processed, stored or transmitted and the associated privacy risks, to determine whether they are acceptable to the organization and manage these accordingly.

# 9.2.10 Controls for Internet security: Vulnerability management

- Information about vulnerabilities of ICT systems being used should be obtained in a timely fashion. The organization's exposure to such vulnerabilities should be evaluated and appropriate measures should be taken to address the associated risk. Configurations, including security configurations of hardware, software, services and networks should be established, documented, implemented, and monitored and reviewed.
- Organizations that supply technology products (firewall, IDS, IPS etc.) and services (network services, VoIP services, managed security services etc.) should consistently and effectively implement measures to identify, handle and disclose vulnerabilities of the products and services they supply. Based on the vulnerabilities disclosed by the product and service vendors, appropriate protection measures shall be implemented to address the vulnerabilities.

# 9.2.11 Controls for Internet security: Network management

- Controls should be implemented to ensure the security of information connected to the Internet and to the protection of connected services from unauthorized access, tampering or damage.
- Controls should be established to safeguard the confidentiality and integrity of data passing over the Internet and to protect the connected systems and applications. Systems connected to the Internet should be restricted and authenticated. Logging and monitoring of network devices and systems associated with the organization's Internet infrastructure, should be applied for recording and detecting actions that can affect Internet security.
- The organization should consider managing the security of systems connected to the Internet by segregating them in DMZ. The perimeter of this segregated network should be well defined and controlled using a gateway (e.g. firewall, filtering router).

# 9.2.12 Controls for Internet security: Protection against malware

- Anti-malware software scans data and programs to identify suspicious patterns associated with malware. To enable detection of new malicious code, it is very important to ensure that the scanning software is always kept up to date, desirably through daily updates.
- Given the potential for new malware to target zero-day vulnerabilities, software that can identify known variants and potential attack patterns should be deployed and kept updated.
- Prevention, detection, correction and recovery measures to protect against malware should be implemented, combined with appropriate user awareness.

# 9.2.13 Controls for Internet security: Change management

- Change management policies and processes should be established addressing requests, priorities, authorization, approval, schedule and implementation of any changes to the ITC infrastructure, systems and applications, in order to prevent unscheduled disruption, data corruption or loss.
- Internet security-related changes for systems hosted on the Internet should be regulated as well by the change management process.
- The Change management process should address responsibilities and duties of system managers, importing software and files, and access control rights.
- All changes (modifications, moves, removals or additions) of network components or structure should be regulated and approved (CCB) to keep the architecture and the infrastructure documentation up to date.

# 9.2.14 Controls for Internet security: Identification of applicable legislation and compliance requirements

- The Internet is increasingly used as a platform to deploy many online transaction services. There can be data security, cybersecurity and privacy laws and regulations on protection of confidentiality, integrity and availability of transaction details.
- Banking transactions, payment channels, mobile app-based transactions and other e-commerce activities are usually regulated due to involvement of money in digital form.
- All information security and cyber security relevant legal, statutory, regulatory and contractual requirements and the organization's approach to meet these requirements should be identified, documented and kept up to date.

# 9.2.15 Controls for Internet security: Use of cryptography

- Cryptography is one of the ways to ensure the protection of the transmitted information.
- Cryptography has some constraints associated with the management of the de/ciphering keys, and the management of the cryptographic devices, which should be considered as confidential and critical at an extra level.
- Cryptography should be used to protect the confidentiality, authenticity and/or integrity of information transmitted over the Internet.
- Cryptographic algorithms, key lengths and usage practices should be selected according to best practice.
- Appropriate key management requires an extra layer of secure processes for generating, storing, archiving, retrieving, distributing, retiring and destroying cryptographic keys.

# 9.2.16 Controls for Internet security: Application security for Internet-facing applications

- New technology can be adopted for systems that are part of the internet infrastructure. The new technology should be analysed for security risks and the design should be reviewed against known attack patterns. Security should be embedded while designing the system. The systems should also be regularly reviewed to ensure that they remain up to date in terms of combatting any new potential threats and in remaining applicable to advances in the technologies and solutions being applied.
- Organizations should adopt secure engineering principles including implementing a secure development life cycle (SDLC) to identify and mitigate risks in products and solutions being developed. This should consider threat modelling, user authentication techniques, supply chain components, secure session control and data validation, sanitization and a security-oriented design review to help identify

# 9.2.17 Controls for Internet security: Endpoint device management

- Information stored on, processed by or accessible via endpoint devices (e.g. IoT devices, USB devices, BYOD) should be protected. Carrying and using endpoint devices in secure areas should be appropriately controlled.
- A security strategy for endpoint device management should be developed and implemented. This strategy should include the management of device firewalls, email specific filtering tools, Internet security and filtering, mobile device management and security tools, encryption and intrusion detection tools.
- Endpoint security has become even more important, as endpoints are moving outside the organizational perimeter and users may use the Internet to access the cloud and resources within the organization's network.

# 9.2.18 Controls for Internet security: Monitoring

- Logs that record activities, exceptions, faults and other relevant events should be produced, protected, kept and analysed. Logs should be protected and kept in a secure location for log analysis and audit for a certain (pre-defined) period of time.
- Internet-facing networks, systems, and applications should be monitored for anomalous behaviour and appropriate actions should be taken to evaluate potential information security incidents.

# Need for a framework for information sharing and cooperation

- A system needs to be established for information sharing and coordination to help responsible organizations to prepare and respond to Cybersecurity events and incidents. The system for information sharing and coordination should be secure, effective, reliable and efficient.
- Methods for sharing and coordinating based on classification/categorization, non-disclosure agreements, code of practice, testing and drills, reciprocal trust framework.

# Thank you!

## For information:

**e-mail**
cybersecurity_info@uniroma1.it

**Web site**
https://cybersecurity.uniroma1.it

**Google drive for handouts**

https://drive.google.com/drive/folders/15-hLIVz4aEroHWc8dkSBqa995iZSJOuT